

Daily QA & Security Work Report

Date: 2026-04-23 **Prepared by:** Perumal **Branch:** login_flow_test_21_04_2026 **App:** Hima (Android)

1. Summary

Today I ran an API-automation pass of the Hima Android **Male Transactions** and **Female Transactions** screens, targeting the two transaction endpoints `/transaction_list` and `/female_transaction`. I ran the suite twice — first with only a male QA account (30 cases) to baseline the male endpoint, then expanded to both a male and a female QA account (45 cases) once a female test number was available. This dual-account run was the important one: it unlocked parts of the female endpoint that the ownership gate had previously hidden, and confirmed which bugs are shared across both endpoints versus male-only.

Across the 45 automated cases I uncovered **6 unique bugs** (1 S1 Critical, 3 S2 High, 2 S3 Medium). I also performed on-device manual verification of both Android patches landed today (BUG-TX-004 and BUG-TX-007) on a real emulator session and confirmed they behave correctly. The headline is a **critical IDOR** on

`/transaction_list`: any logged-in user can read any other user's complete financial history just by sending a different `user_id` in the POST body. Proof: male QA token (id 456976) fetched 272 rows belonging to female QA (id 456740) on demo, and separately 8,926 rows belonging to a female user (id 72530) on prod. The sibling `/female_transaction` endpoint already enforces the ownership check correctly — the fix is a copy-paste from that controller.

Branch status: I landed the two Android-side mitigations that were possible (nullable schema fields + error observer). Both compiled cleanly with `./gradlew :app:compileDevelopmentDebugKotlin` → BUILD SUCCESSFUL, zero new warnings. The other four bugs are **server-only** — there is no client-side code change that closes them, because a curl user or patched APK bypasses any app guard. Those four are fully documented for the backend team with exact Laravel validator snippets. No push to `main` — pending senior review and on-device verification of the two Android patches.

2. Testing Performed

2.1 API Testing

Black-box API testing against the dev backend (`https://demohima.himaapp.in/api/auth`) using a Python test harness that drives `urllib` directly — independent of the Android client. Functional, pagination, boundary, negative, security (IDOR / `auth` / `SQLi` / `gender-gate` / `cross-endpoint`), HTTP-verb correctness, response-contract and performance p95 cases. Read-only suite — no transaction was created, no call placed, no coin deducted.

- Exercised 2 endpoints: `/transaction_list` and `/female_transaction`, with BOTH a male-token and female-token context for cross-account / `gender-gate` coverage (cases prefixed `TXX-*`).
- Confirmed **CRITICAL IDOR on `/transaction_list`**: the endpoint trusts the body `user_id` instead of deriving it from the JWT subject. Proven on both demo (male→female 456740, 272 rows) and prod (male→female 72530, 8,926 rows) — **BUG-TX-001**. The sibling `/female_transaction` correctly blocks this in both directions (TXX-01, TXX-02 passed), so the fix pattern already exists in the codebase.
- Confirmed **HTML 500 leak on `limit=-1` on both endpoints** (BUG-TX-004). Server returns the Laravel HTML error page instead of JSON. Reachable on the female endpoint only once we had a female token — this was a new dual-account finding.
- Confirmed **no server-side cap on `limit` on both endpoints** (BUG-TX-005). `limit=99999` returned 272 rows on the female endpoint and 272 rows on the male endpoint in a single response. Compound with BUG-TX-001 → a one-shot scrape of any user's full history.

- Confirmed **schema mismatch** (BUG-TX-007): `/transaction_list` responses are missing `user_name`, `call_type`, `duration`, `call_user_name` — fields declared non-nullable in `TransactionsResponse.kt`. Today Gson silently fills with null; future Kotlin 1.9 upgrade makes this a hard crash on the Transactions screen.
- Confirmed **silent negative-offset coercion** on **both** endpoints (BUG-TX-003). `offset=-1` and `offset=0` return identical `first_id` — server silently coerces instead of rejecting.
- Confirmed **HTML 302 fallback** when `Accept: application/json` is absent (BUG-TX-002). Retrofit always sets this header so the shipping app is fine today — but non-Retrofit consumers / dropped-header interceptors will crash their JSON parser. Caught only when we bypassed the header explicitly.
- Positive result: `/female_transaction` is the **hardened reference**. Ownership check fires bidirectionally (TXX-01, TXX-02), gender gate works (TXX-04), all 10 Kotlin fields are present (TXF-02), SQLi probes rejected early (TXF-08), tampered JWT rejected (TXF-15). Every shared bug (BUG-TX-003, 004, 005) has the same server-side validator fix that closes both endpoints in one change.
- Total cases executed: **45** (24 male endpoint · 17 female endpoint · 9 cross-account / cross-endpoint). Result: 35 PASS / 10 FAIL, mapping to 6 unique bugs.
- Artifacts: `QA_Reports/automation/transactions_api_tests.py` (reproducible suite), `QA_Reports/automation/transactions_api_report.html` (interactive), `QA_Reports/automation/hima_automation_tests.pdf` (tech-lead PDF), `QA_Reports/automation/transactions_api_results.json` (raw results).

2.2 UI Automation Testing

No new UI automation cases were authored today — the transaction screens do not yet have an Espresso / UIAutomator suite, and yesterday's voice-verification live driver remains the only UI automation checked in. Adding UI automation for the Transactions screens is a candidate for the next QA sprint; the API tests shipped today are the complementary layer below any UI automation we build.

2.3 User-Perspective Testing

Hands-on on-device walkthrough performed by me on the emulator after the two Android patches were compiled and sideloaded. Both fixes verified; no regression detected on adjacent flows.

- **BUG-TX-007 fix verified on device:** Logged in as a male user with call- deduction history. Opened the Transactions screen. Rows render cleanly — no literal "null" appears in the title or date line. The old "Audio session with null" / "Apr 23 · null" artefacts are gone. Rows that DO have a call-user name still render correctly (no behavioural regression on populated fields).
- **BUG-TX-004 fix verified on device:** Enabled airplane mode, killed and reopened the app, tapped Transactions. The new observer fires correctly: a toast appears and the "No records" fallback view shows, instead of the previous silent blank screen. Disabled airplane mode, re-opened the screen — the list loads normally (no stale-error state).
- **Regression smoke:** Female account on the Female Transactions screen still renders correctly, pagination still advances across pages, no crash on open, no visual regression introduced by the shared-class changes.

Verification status: Both Android-side mitigations (BUG-TX-004 and BUG-TX-007) are **verified on device by me** in addition to compiling cleanly. Claude only produced the code under my direction — the device-level confirmation that the UX actually behaves correctly is my own manual work.

3. Bug Status — All 6 Defects

Status legend: *Fully fixed* (client-side change complete, no backend dependency), *Partially fixed* (client-side mitigation landed, backend fix still required for full remediation), *Documented* (no meaningful client-side action possible — backend fix required).

ID	Title	Severity	Status
BUG-TX-001	IDOR on /transaction_list — any user can read any other user's financial history	S1 Critical	Documented
BUG-TX-004	limit=-1 on /transaction_list AND /female_transaction returns HTML 500 error page	S2 High	Partially fixed
BUG-TX-005	Neither endpoint caps 'limit' — limit=99999 returns full history (DoS/OOM surface)	S2 High	Documented
BUG-TX-007	TransactionsResponse.kt declares 4 non-null fields the server never sends (Gson crash risk)	S2 High	Partially fixed
BUG-TX-002	/transaction_list returns HTML 302 → /login when Accept:json header absent	S3 Medium	Documented
BUG-TX-003	Negative offset silently coerced to 0 on BOTH endpoints (off-by-one pagination risk)	S3 Medium	Documented

Totals: 0 fully fixed, 2 partially fixed, 4 documented for backend fix.

Why so few fully fixed? Four of the six bugs are server-side root causes (IDOR, pagination cap, offset validator, JSON error handler). A client-side change cannot close them — a curl user or a patched APK bypasses any app-side guard and still exploits the endpoint directly. The two bugs with Android surface area (BUG-TX-004 HTML-500 blank screen and BUG-TX-007 schema mismatch) have client-side mitigations landed today, but each still needs the backend counterpart to be considered fully closed. For everything else, the correct QA outcome is "documented with repro + recommended fix for backend".

4. Client-Side Changes Landed Today

4.1 TransactionsResponse.kt — nullable schema + amount type (Partially fixed BUG-TX-007)

- Changed 6 fields from non-null `String` to nullable `String?`: `user_name`, `date`, `call_type`, `duration`, `call_user_name`, `payment_type`. The server never sends these today — the old data class was lying to the compiler.
- Changed `amount: Int` → `amount: String?`. The server returns a decimal-formatted string (`"3.00"`), not an integer. Gson previously silently coerced — a crash waiting to happen on any device where the coercion path differs.
- Added a one-line comment explaining why `amount` is a string, so a future developer doesn't "fix" it back to `Int`.

Backend still required: the server should emit the documented keys (empty-string fallback) so the API contract is stable for any future consumer. Otherwise a third-party integration will run into the same surprise.

4.2 TransactionAdapter.kt — null-safe rendering (Partially fixed BUG-TX-007)

- Replaced direct string-template use of `transaction.call_user_name` and `transaction.duration` with local vars that use `.orEmpty()` before interpolation. Same for `transaction.date`.
- Conditional rendering: `"$callType session with $callUserName"` degrades to `"$callType session"` when `callUserName` is empty. `"$dateText · $durationText"` degrades to just `dateText` when duration is empty. No more literal "null" text visible on screen.
- No behavioural change for rows where the fields ARE populated — tested via compile + static review; device verification pending.

4.3 TransactionsActivity.kt — error observer for non-JSON responses (Partially fixed BUG-TX-004)

- Added an observer on `transactionsViewModel.transactionsErrorLiveData` — the ViewModel already posts to this LiveData on `onFailure` and `onNoNetwork` (see `TransactionsViewModel.kt:36–42`), but until today nobody was listening on the male screen. The female screen already had this observer (`FemaleTransactionsActivity.kt:128–137`) — I mirrored its logic.
- On error, the observer shows a toast — "No internet connection" if `error == DConstants.NO_NETWORK`, otherwise "Please try again later" — AND displays the "No records" fallback view. This replaces today's silent-blank-screen behaviour when the server returns HTML 500 on `limit=-1`, HTML 302 without `Accept:json`, or any network failure.
- Imports added: `android.util.Log`, `android.widget.Toast`, `com.gmwapp.hima.constants.DConstants`. No other file touched.

Backend still required: the server should not return HTML 500 at all (BUG-TX-004) and should never return HTML 302 for `/api/*` routes (BUG-TX-002). The client observer is a defensive UX fix — it makes the symptom less harmful, but the underlying server bug remains.

5. Documented-Only Bugs (backend fix required)

These bugs have no meaningful client-side mitigation — the root cause is on the server and any attacker bypasses client guards. They are captured in the API test report with repro steps, proofs, and recommended fixes for the backend team.

- **BUG-TX-001** — `/transaction_list`: derive `user_id` from JWT `sub`; ignore body `user_id`. The sibling `/female_transaction` already does this — copy that pattern. Suggested one-liner: `abort_if($request->input('user_id') != $request->user()->id, 403);`
- **BUG-TX-002** — force JSON 401 for `request()->is('api/*')` in Laravel's exception handler, regardless of the Accept header. Currently the web auth guard returns HTML 302 → `/login` which breaks any non-Retrofit client.
- **BUG-TX-003** — add `'offset' => 'nullable|integer|min:0'` FormRequest validator on **both** `/transaction_list` and `/female_transaction`. Currently negative offsets are silently coerced to 0, enabling a subtle double-render bug if a client pagination miscalculates.
- **BUG-TX-005** — add `'limit' => 'nullable|integer|min:1|max:100'` on **both** endpoints. Currently `limit=99999` returns the full user history in one payload — exhausts DB connections and Gson parse memory. `$data->take(min($limit, 100))` in the controller as a belt-and-braces second line of defence.

BUG-TX-004 and BUG-TX-007 also have backend counterparts (limit validator, and emit-all-keys for contract stability) — those are not duplicated here because they are documented under the "partially fixed" bugs in section 3.

6. Files Changed on Branch

File	Change
app/src/main/java/com/gmwapp/hima/retrofit/responses/TransactionsResponse.kt	Marked 6 fields nullable (user_name, date, call_type, duration, call_user_name, payment_type) to match what the server actually sends. Changed amount: Int → String? because the server returns a decimal-formatted string ("3.00"), not an integer. Closes the Gson-NPE / future Kotlin

File	Change
	1.9 crash path for BUG-TX-007.
app/src/main/java/com/gmwapp/hima/adapters/TransactionAdapter.kt	Null-safe rendering for the now-nullable fields: call_user_name, date, duration all use .orEmpty(); "\$callType session with \$callUserName" degrades to "\$callType session" when name is missing (no more "Audio session with null" visible on screen).
app/src/main/java/com/gmwapp/hima/activities/TransactionsActivity.kt	Added transactionsErrorLiveData observer — mirrors what FemaleTransactionsActivity already does. When the server returns a non-JSON response (HTML 500 / HTML 302 / network failure), the user now sees a toast ("No internet connection" or "Please try again later") and the "No records" fallback view, instead of a silent blank screen. Closes the Android side of BUG-TX-004.

All changes compile cleanly: `./gradlew :app:compileDevelopmentDebugKotlin` → **BUILD SUCCESSFUL**. Only pre-existing deprecation warnings remain (e.g. `statusBarColor`), none introduced by today's edits.

7. Work Attribution — What I Did vs What Claude Assisted With

Being transparent about tooling: AI assistance (Claude Code) was used for API harness scripting, code edits, bug explanations, and report generation under my direction. All testing judgment calls, safety rules, branch hygiene, and the QA report content are my own.

7.1 Done by me (Perumal)

- Scoped the target: Transaction activity on both male and female screens. Decided that API-automation layer was the priority today (UI automation for these screens is a future item).
- Provided the female QA test number (9120444444) with the QA backdoor OTP (011011) so the female endpoint could actually be exercised past its ownership gate — the earlier male-only run had artificially passed most of the female cases because the ownership check was blocking them first.
- Set safety rules before any test ran: **read-only suite, no transaction creation**, no call started, no coin deducted, no profile mutation. Claude respected this — the 45-case suite never hits any mutating endpoint.
- Reviewed every code change before it landed on the branch. Confirmed the two Android patches were the only client-side mitigations with meaningful impact; approved the scope.

- Called out my concern when the initial Fix-ownership breakdown in the HTML report showed overlapping categories (2 + 2 + 6 summing to 10 from 6 failures) vs the PDF's disjoint 0 + 2 + 4 = 6. That forced a fix that made both reports tell the same story.
- Decided the severity for each bug: BUG-TX-001 as S1 Critical (financial-data privacy leak across all users), BUG-TX-004/005/007 as S2 High, BUG-TX-002/003 as S3 Medium.
- **Performed on-device manual verification** of both Android patches (BUG-TX-004 and BUG-TX-007) on the emulator. Confirmed the Transactions screen renders cleanly with no literal "null" artefacts, and confirmed the new error observer shows the toast + "No records" fallback under airplane-mode conditions. Ran the regression smoke on the female screen to make sure nothing adjacent broke. Claude did not do any runtime / emulator work — only the code edits + compile check.
- Kept the branch local (no push to `main`) — pending senior review.
- Scoped what to ask for vs defer: declined to add more automation rounds once the 45-case suite was stable; asked for the report in different visual styles (dark tech-lead PDF and light executive PDF) to choose which to forward to the tech lead.

7.2 Used Claude for

- Built the Python API test harness (`transactions_api_tests.py`) — 45 cases across functional, pagination, boundary, security (IDOR / SQLi / cross-account), contract, performance categories. I defined the endpoints, accounts and safety scope; Claude wrote the harness under that brief.
- Applied the two Android-side patches (`TransactionsResponse.kt` nullable fields, `TransactionAdapter.kt` null-safe rendering, `TransactionsActivity.kt` error observer) under my direction, then ran the Kotlin compile to verify zero new warnings.
- Plain-language explanations of each bug (what's wrong, why it hurts, how to fix) for the tech-lead-facing PDF — so a non-QA reader can triage the list without reading the raw JSON.
- Generated both the dark interactive HTML report (`transactions_api_report.html`) and the light executive PDF (`hima_automation_tests.pdf`) via Chrome headless HTML-to-PDF. I picked which style to forward.
- Diagnosed and fixed the "overlapping vs disjoint fix-ownership counters" bug in the HTML report when I flagged the mismatch with the PDF.
- Generated this daily report (HTML + PDF) matching yesterday's (`Daily_Report_2026-04-22.pdf`) visual style.

8. Pending / Asks for Senior & Backend

- **Backend pickup of 4 documented-only bugs:** BUG-TX-001 (critical IDOR), BUG-TX-002 (JSON 401), BUG-TX-003 (offset validator), BUG-TX-005 (limit cap). All have specific Laravel FormRequest / exception-handler snippets in the API report. Additionally the server sides of BUG-TX-004 (limit validator) and BUG-TX-007 (emit all declared keys) — client side is landed.
- **Priority:** BUG-TX-001 first, same day if possible. One-liner backend change, mirrors existing `/female_transaction` logic. Closes the financial-data privacy leak across all users on prod right now.
- **On-device verification: DONE today.** Both patches manually tested by me on the emulator — see section 2.3. No further QA blocker on the Android-side work.
- **Senior approval** to add the three Android-side changes to the existing `login_flow_test_21_04_2026` branch, or to cut a separate `transactions_fixes` branch. Either is fine — flagging because yesterday's login-flow + edit-profile work is already on this branch and the diff is growing.
- **Next QA target:** pending your direction. Candidates: Wallet / Payment flow (real-money surface, same IDOR / validator risk), Friends / Block / Report, Withdraw / KYC (female creator payout). Happy to go where the tech lead sees the most risk.

9. Artifacts

- `QA_Reports/automation/transactions_api_tests.py` — reproducible API test suite (45 cases, dual-account, read-only).
- `QA_Reports/automation/transactions_api_report.html` and `hima_automation_tests.pdf` — API test report (interactive HTML + tech-lead PDF, two visual styles). The older `Hima_Transactions_API_Test_Report.pdf` is kept alongside for diff.
- `QA_Reports/automation/transactions_api_results.json` — raw results JSON for auditability.
- `QA_Reports/automation/make_transactions_pdf_report.py` and `make_hima_automation_pdf.py` — the two PDF-renderer scripts, re-runnable on demand.
- `QA_Reports/Daily_Report_2026-04-23.pdf` — this report.

End of report — 2026-04-23